

¿Qué es IriusRisk?

IriusRisk es una plataforma de modelado de amenazas y gestión de riesgos de seguridad diseñada para integrar la seguridad desde el inicio del ciclo de vida del desarrollo de software (SSDLC). Permite a los equipos de desarrollo y seguridad identificar, evaluar y mitigar riesgos de seguridad de manera automatizada, asegurando que las aplicaciones sean seguras antes de ser desplegadas.

¿Para qué sirve?

IriusRisk ayuda a organizaciones a:

- ✓ Automatizar el modelado de amenazas, generando recomendaciones de seguridad en función de la arquitectura del sistema.
- ✓ Definir controles de seguridad desde la fase de diseño, reduciendo costos y tiempos de remediación.
- ✓ Integrarse con herramientas de desarrollo y seguridad, facilitando la adopción del SSDLC.
- ✓ Generar reportes de cumplimiento alineados con estándares como OWASP, NIST, ISO 27001 y PCI-DSS.

¿Cómo funciona?

- 1 ☐ Ingreso de arquitectura: Se modela el sistema mediante diagramas o descripciones técnicas.
- 2 ☐ Evaluación de amenazas: La plataforma identifica riesgos potenciales basándose en bases de datos como STRIDE y OWASP ASVS.
- 3 ☐ Generación de controles de seguridad: Se sugieren medidas específicas para mitigar amenazas.
- 4 ☐ Seguimiento y gestión: Se asignan tareas y se da seguimiento a la implementación de controles.
- 5 ☐ Integración con DevSecOps: Compatible con herramientas como Jira, Jenkins y SonarQube para un flujo de trabajo ágil.

Ventajas de IriusRisk

- ✓ Automatización del modelado de amenazas, reduciendo la carga manual en seguridad.
- ✓ Mejora la colaboración entre equipos de desarrollo, seguridad y operaciones.
- ✓ Facilita la auditoría y el cumplimiento de normativas de ciberseguridad.

1. Creación del Diagrama de Flujo de Datos (DFD):

- **Elementos:** Defines componentes como bases de datos, APIs, interfaces de usuario, servicios en la nube, etc., y cómo interactúan.
- **Flujos de Datos:** Muestras el movimiento de información sensible (datos personales, credenciales) entre estos componentes.
- **Límites de Confianza:** Defines las zonas donde el nivel de confianza cambia (ej., entre una red interna y una externa).

2. Identificación Automatizada de Amenazas:

- **Frameworks:** IriusRisk utiliza modelos como STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) para categorizar amenazas.
- **Aplicación:** Al conectar los DFDs, la herramienta detecta dónde se manejan datos sensibles y propone amenazas específicas (ej., "Information Disclosure en flujo de datos de registro de usuario").

3. Generación de Contramedidas (Controles):

- **Recomendaciones:** IriusRisk sugiere controles obligatorios y recomendados para mitigar las amenazas identificadas (ej., cifrado de datos en tránsito, autenticación multifactor).

4. Priorización y Mitigación:

- **Riesgo:** La plataforma calcula el nivel de riesgo (ej., usando puntuaciones) para que los equipos prioricen las amenazas más críticas.
- **Integración:** Las mitigaciones se convierten en tareas para los equipos de desarrollo, integrándose en sus sprints y flujos de trabajo de CI/CD.

Ejemplo Concreto (Aplicación Web de E-commerce):

- **Componentes:** Módulo de inicio de sesión, carrito de compras, pasarela de pago, base de datos de clientes.
- **Flujo:** Usuario ingresa credenciales -> API -> Base de Datos (verifica) -> API -> Módulo de inicio de sesión.

- **Amenaza (STRIDE):** "Information Disclosure" (Divulgación de Información) en el flujo de credenciales al BBDD sin cifrar.
- **Contramedida (IriusRisk):** Implementar TLS/SSL en la comunicación API-BBDD y cifrar las contraseñas en la base de datos.
- **Resultado:** El equipo de desarrollo recibe la tarea de implementar el cifrado, asegurando el cumplimiento desde el diseño.

El modelado de amenazas en IriusRisk es un proceso automatizado que traduce diagramas de arquitectura en una lista priorizada de riesgos y contramedidas. A continuación, se presenta un ejemplo práctico de cómo [modelar una aplicación web](#) básica en 2026:

1. Definición del Escenario

Imagine una aplicación que consta de un **Navegador de Usuario**, un **Servidor Web** y una **Base de Datos**.

2. Creación del Diagrama (Arquitectura)

En la interfaz de IriusRisk (o usando la herramienta integrada [Draw.io](#)), se arrastran y sueltan los siguientes componentes:

- **Trust Zones (Zonas de Confianza):** Se define una zona de "Internet" (baja confianza) y una "Zona Corporativa" (alta confianza).
- **Componentes:** Se añade un "Browser" en la zona de Internet y un "Web Server" con su "SQL Database" en la zona corporativa.
- **Flujos de Datos:** Se dibuja una conexión HTTPS del usuario al servidor y una conexión SQL del servidor a la base de datos.

3. Generación Automática de Amenazas

Al guardar el diagrama, el motor de IriusRisk analiza las interacciones y aplica la metodología **STRIDE** para identificar riesgos automáticamente:

- **Ejemplo de Amenaza Identificada:** "Inyección SQL en la base de datos" o "Spoofing de identidad en el login".
- **Uso de IA (Jeff):** En 2026, puedes usar el asistente **Jeff AI** para generar este modelo simplemente subiendo una imagen de la arquitectura o una descripción en texto (prompts).

4. Selección de Contramedidas

La herramienta genera una lista de controles de seguridad obligatorios o recomendados:

- **Para la base de datos:** Implementar consultas parametrizadas (para evitar SQLi).
- **Para el flujo de datos:** Forzar el uso de TLS 1.3.

5. Gestión y Resultados

- **Estado:** El equipo marca cada contramedida como *Implementada*, *Rechazada* o *No Aplicable*.
- **Reportes:** Se genera un informe técnico (PDF/HTML) que muestra el riesgo residual y el cumplimiento de estándares como OWASP.

Este enfoque permite a los equipos de ingeniería planificar la seguridad **antes** de escribir el código, integrándose directamente en flujos de trabajo como Jira o Azure DevOps.

NOTA: si quieres observar un video de Irius Risk puedes consultar los siguientes links:

https://www.youtube.com/watch?v=3fIQp3f_E8Q

<https://www.youtube.com/watch?v=GxYDd9WsFtY>

OWASP Threat Dragon

Un ejemplo de modelado de amenazas con OWASP Threat Dragon implica **descomponer un sistema** (ej. una app de banco) en componentes (usuario, web, BD), **dibujar flujos de datos** en el lienzo (con formas para componentes, límites, etc.), **identificar amenazas** usando un marco como STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) para cada flujo/componente, y luego **asignar mitigaciones** como TLS<</ o mTLS para reducir riesgos, exportando el modelo en JSON para compartirlo o revisarlo.

Pasos clave en Threat Dragon

1. **Crear Diagrama:** Inicias con un lienzo y lo llamas (ej. "e-bank").
2. **Descomponer (Diagrama de Flujo de Datos):**
 - Añades componentes (cajas) como `Usuario`, `Aplicación Web`, `Base de Datos`.
 - Añades límites (líneas) entre redes (ej. Internet, Red Interna) para indicar zonas de confianza.
 - Dibujas flechas (flujos de datos) entre componentes, indicando qué datos pasan (ej. credenciales, info financiera).
3. **Identificar Amenazas (Usando STRIDE):**
 - Seleccionas un flujo de datos o un componente en el diagrama.
 - En el panel de amenazas, añades una amenaza (ej. Spoofing) y la asocias a ese elemento.
 - Puedes detallar la amenaza (descripción, prioridad, severidad).
 - *Ejemplo:* Sobre el flujo de `Usuario -> Aplicación Web`, podrías identificar amenazas de Spoofing (suplantación de identidad) o Tampering (manipulación de datos).
4. **Diseñar Mitigaciones:**
 - Para cada amenaza, defines una contramedida (ej. para Spoofing, implementar autenticación fuerte/mTLS).
 - Las amenazas se marcan como mitigadas una vez implementados los controles.
5. **Generar Reporte:** Puedes exportar el modelo completo a PDF o JSON para documentar y compartir con el equipo.

Ejemplo Práctico (Microservicios Financieros)

- **Componentes:** Servicio Autenticación, Servicio de Pagos, Base de Datos de Usuarios.
- **Flujo:** Servicio Auth llama a Servicio Pagos con token de usuario.
- **Amenaza (STRIDE):** [Information Disclosure](#) (divulgación de información) si el token viaja sin cifrar.
- **Mitigación:** Implementar [Transport Layer Security](#) (TLS) mutuo (mTLS) para cifrar la comunicación entre servicios y asegurar la identidad de cada uno.

NOTA: Puedes consultar este video de muestra de una demostración práctica de OWASP Threat Dragon: